

Acme Corporation Legal and Compliance Manual

Policy Manual — Edition 2022

1. Data Retention

Customer personal data is retained for the duration of the contract plus 60 days. Backups are retained for 30 days on a rolling basis. Financial records are retained for 7 years in accordance with statutory requirements. Deletion requests from data subjects must be fulfilled within 30 days.

2. GDPR Compliance

Acme processes personal data of EU residents under the lawful bases of contract performance and legitimate interest. The Data Protection Officer can be reached at dpo@acmecorp.example. Data Processing Agreements are required with all sub-processors. Cross-border transfers rely on Standard Contractual Clauses.

3. CCPA Compliance

California residents have the right to know what personal information is collected, the right to delete, and the right to opt out of the sale of personal information. Acme does not sell personal information. Requests may be submitted through the privacy portal at privacy.acmecorp.example.

4. Incident Response

Security incidents must be reported to the Security Team within 2 hours of discovery. Confirmed personal data breaches must be reported to the relevant supervisory authority within 72 hours. Affected data subjects must be notified without undue delay if the breach poses a high risk to their rights and freedoms.

5. Acceptable Use

Company systems may not be used for personal commercial activity, cryptocurrency mining, or the storage of illegal content. Personal use of email and internet is permitted within reasonable limits. All company devices must have full-disk encryption and automatic screen lock enabled.

6. Vendor Management

All vendors with access to customer data must undergo a security review before onboarding and annually thereafter. Vendors must provide SOC 2 Type II reports or equivalent. Contracts must include data protection, confidentiality, and breach notification clauses.